

Конфиденциальные данные в логах

Описание проблемы

Ведение журнала событий является хорошей практикой обеспечения безопасности. Однако, если в журналы записывается конфиденциальная информация, злоумышленник, получивший к ним доступ, также получает конфиденциальные данные.

В настоящий момент доступ к просмотру боевых и fix логов есть у большого количества сотрудников и не существует способов выборочного сокрытия конфиденциальных данных.

Примеры

Сессия

```
Ответ:
1 {
2   "jsonrpc": "2.0",
3   "result": {
4     "f": 0,
5     "d": [
6       [
7         "ИдСессии",
8         "00af4518-00af4518-00be-c2a2745e76bd44c3"
9       ],
10      [
11        "ИдПользователя",
12        "11486488"
13      ],
14      [
15        "ИдПерсоны",
16        "d4536664-ac32-496d-b3c7-97c05df7e231"
17      ],
18    ]
19  }
20 }
```

Данные банковских счетов

```
Запрос:
14   "Дата": "01.05.2022",
15   "ПериодыПоУходу": [
16     {
17       "ЧленСемьи": {
18         "Фамилия": "Клубничный",
19         "Имя": "Тимур",
20         "ДатаРождения": "25.04.2022",
21         "ПорядковыйНомер": "Первый"
22       },
23       "ДатаНачала": "02.05.2022",
24       "ДатаКонца": "31.05.2023"
25     }
26   ],
27   "Оплата": {
28     "Счет": {
29       "НомерКарты": "23322332",
30       "БИК": "044525074",
31       "НомерСчёта": "222222222222222222"
32     },
33     "СпособПлаты": "Карта МИР"
34   }
35 }
```

Ответ:

Токены

Запрос:

```

1 {
2   "jsonrpc": "2.0",
3   "method": "ExternalAuth.GetUserByToken",
4   "params": {
5     "Token": "vBVcET22iR1J56xMtpFYMEItDjNzaaUnj6BRDXMug5Va0lgwteLVuT
6   },
7   "protocol": 6,
8   "id": 0
9 }

```

```

{
  "jsonrpc": "2.0",
  "method": "PotentialMember.UpdateToken",
  "params": {
    "email": "totest_outside9@dev.tensor.ru"
    "token": "eyJlbWFpbCI6ICJ0b3Rlc3Rfb3V0c2
  },
  "protocol": 7,
  "id": 0
}

```

Персональные данные

```

4   "params": {
5     "ДопПоля": null,
6     "Фильтр": {
7       "f": 0,
8       "d": [
9         [
10          "c-b1a232d8-c8b9-40fc-b5b8-c7676b793482"
11        ],
12        [
13          "DepartmentPath"
14        ]
15      ],
16      "s": [
17        {
18          "n": "DeviceIds",
19          "t": {
20            "n": "Массив",

```

Ответ:

```

316     "n": "INN",
317     "t": "Строка"
318   },
319   {
320     "n": "SNILS",
321     "t": "Строка"
322   },
323   {
324     "n": "DocType",
325     "t": "Число целое"
326   },
327   {
328     "n": "DocSeries",
329     "t": "Строка"
330   },
331   {
332     "n": "DocNumber",
333     "t": "Строка"
334   },

```

Пароль

Запрос:

```

1 {
2   "jsonrpc": "2.0",
3   "method": "User.WriteWithHistory",
4   "params": {
5     "Запись": {
6       "f": 0,
7       "d": [
8         103942593,
9         "Тест123"
10      ],
11      "s": [
12        {
13          "n": "@Пользователь",
14          "t": "Число целое"
15        },
16        {
17          "n": "Пароль",
18          "t": "Строка"
19        }
20      ]
21    }
22  }
23 }

```

Последствия эксплуатации

Последствия утечки могут быть разнообразными. Утечка учетных данных может привести к получению доступа к аккаунтам и упрощению атак на инфраструктуру компании, например:

1. Доступ к базам данных, серверам, сетевым хранилищам может использоваться для порчи или подмены данных клиентов.
2. Утечка боевых или fix логина-пароля, sid, тикета или токена от боевых сайтов позволит:
 - Получить доступ к внутренним документам компании и переписке;
 - Получить доступ к аккаунтам клиентов;
 - Удаленный доступ к рабочим ПК через удаленный помощник;
 - Нанести репутационный ущерб компании.
3. Диверсии на наших или сторонних сервисах через аккаунт компании.
4. Дискредитации клиентов или нашей компании.

Как исправить?

Не допускать утечки конфиденциальных данных. Для этого:

1. Не логировать конфиденциальные методы на бою и fix.
2. При логировании sid'a использовать **HashSidSecretPart**.

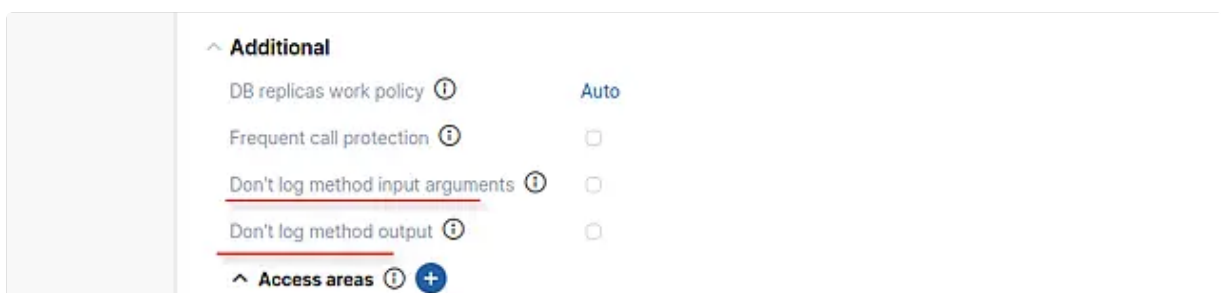
- [Python](#)

```
1 sess_id = ':' + HashSidSecretPart(Session.ID()) # HandlerName + ':'  
  + Session.ID()  
2     return SqlQueryScalar( '''SELECT "ПриостановленоДо" FROM  
  "ОчередьСлужебныхСобытий"  
3                               WHERE "Пользователь" = $1 AND  
  "НашаОрганизация" = $2  
4                               LIMIT 1''' , sess_id, OurOrg )
```

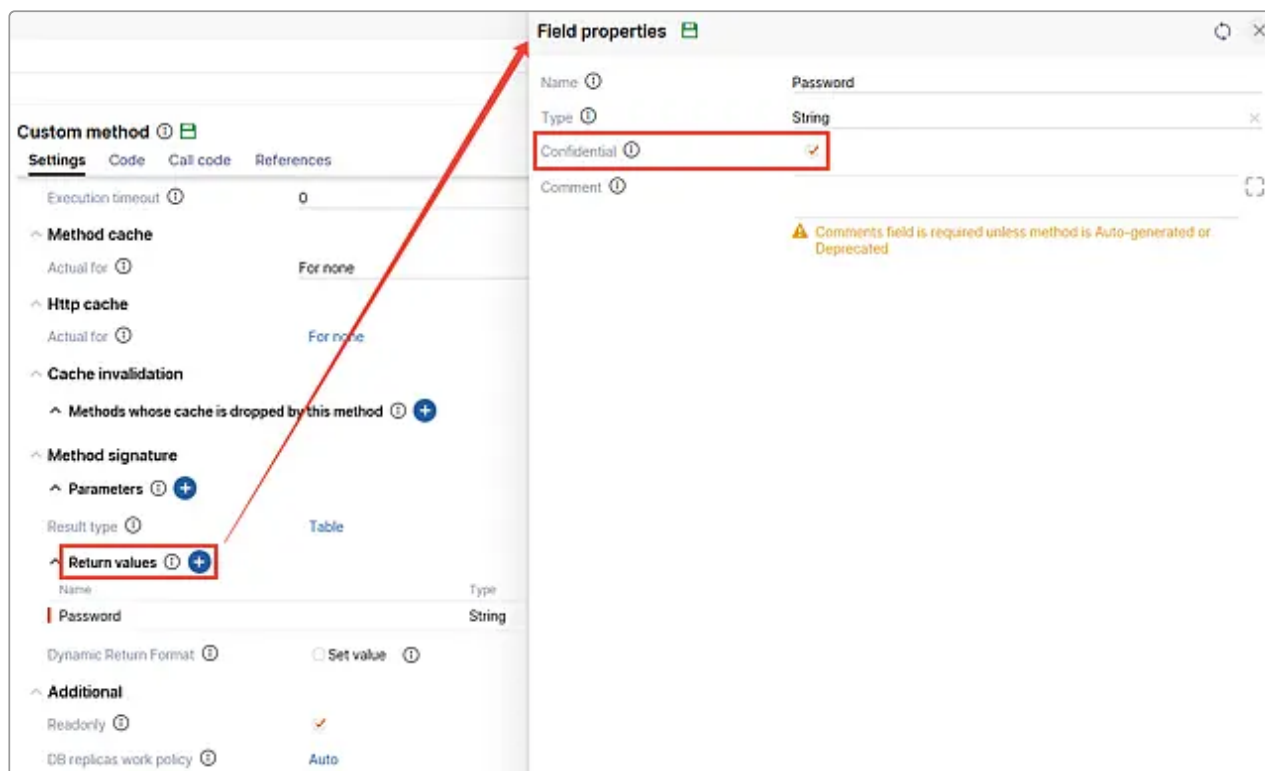
- [C++](#)

```
1 const String& sid = error_msg.TestFieldNotNull(L"SID")  
2                               ?  
  HashSidSecretPart(error_msg[L"SID"].Ref<String>())  
3                               : L"";
```

3. Если метод принимает конфиденциальные данные в Genie нужно отметить флаг "Don't log method input arguments" или "Don't log method output" если конфиденциальные данные возвращает.



У возвращаемых параметров есть признак конфиденциальности, выставление которого запретит логирование конкретного параметра. В логах значение параметра будет заменено заглушкой.



4. Добавлять заголовок Cookie в платформенный [HTTP-клиент](#) только через функцию **AddPrivateHeader**. Иначе все Cookie будут записаны в логи.

- Python

```

1 def test_private_header(self):
2     self.cli.AddPrivateHeader('server')
3     self.cli.AddPrivateHeader('date')
4     self.cli.AddPrivateHeader('auth')
5     self.cli.AddPrivateHeader('user-agent')
6     self.cli.RequestHeaders = {'auth': 'secret'}
7     # сделаем запрос, скрытые заголовки смотреть в логге
8     self.cli.Get(self.url("html"))
1  for header in private_headers or []:
2      http_client.AddPrivateHeader(header)

```

- C++

```

1 if( !req.mPrivateHeaders.empty() )
2 {
3     for( auto& header_name: req.mPrivateHeaders )
4         http_client.AddPrivateHeader( std::move( header_name ) );
5 }

```

5. Использовать расширенное логирование и логирование Redis на бою только в случае крайней необходимости и на короткий период.

6. Если конфиденциальные данные вашего метода видны в [Graylog](#), то нужно написать задачу на ответственного за Graylog. Он поможет спрятать данные.